LABORATUVAR 6 · GENEL SÜRÜM · Şişeleme Hattı

CRA Incident Simulation

Çıktı: Incident Workflow

Ad Soyad Hassan Chawa | Grup Yazılım Müh. | Tarih 23 Ekim 2026

Senaryo: Saat **10:15**. Servis hesabında yetkisiz erişim tespit edildi. PLC konfigürasyonu değişmiş olabilir. Makine hâlâ çalışıyor. Vardiya sorumlusu sizsiniz.

Kavram: Bir olayda en değerli iki şey **zaman** ve **kanıt**tır. CRA'nın 24s / 72s / 14 gün yükümlülükleri, iyi bir müdahale akışının doğal kilometre taşlarıdır — ezber değil.

Görev — zaman çizgisini doldurun

1. **10:15 — ilk 15 dk:** Kimi ararsınız? İlk üç eyleminiz?

Kimi ararsınız: vardiya amiri, safety sorumlusu, BT/siber güvenlik ve PLC bakım ekibi; sonra CRA/uyum sorumlusu. İlk üç eylem: (1) Hat ve araçlar kontrollü durdurulur, insan erişimi kısıtlanır; yeniden başlatma yapılmaz. (2) Servis hesabı ve VPN oturumları derhal kapatılır. (3) Olay kaydı açılır (saat, kim, ne görüldü), PLC konfigürasyonu dondurulur.

2. **İlk 2 saat:** Emniyet güvende mi? Neyi korursunuz (kanıt!)? Hangi hesap kapatılır?

Emniyet: Safety PLC ve LiDAR konfigürasyonu değişmiş mi, güvenli durum doğrulandı mı kontrol edilir; şüphe varsa araç işletimden çıkarılır. Korunacak kanıt: servis hesabı logları, IP ve zaman damgaları, PLC konfigürasyon yedeği (öncesi ve hash'li), jump server ve VPN kayıtları. Kapatılacak hesap: yetkisiz erişimde kullanılan servis hesabı ve ilişkili tüm tokenlar.

3. **24 saat — CRA erken uyarı:** Hangi bilgi hazır olmalı?

Erken uyarı için hazır olmalı: olayın tespit zamanı ve kaynağı, etkilenen sistem (FTC30 PLC, servis hesabı), aktif sömürü olup olmadığı, alınan geçici önlemler ve bildirim sorumlusu. Kök neden kesinleşmemiş olabilir; bu erken uyarıda açıkça belirtilir.

4. **72 saat — CRA bildirim:** Kök neden, etki, önlem — kim ne yapıyor?

Kök neden: servis hesabının çalınmış/zayıf kimlik bilgisi ve fazla yetkisi (doğrulanacak). Etki: PLC konfigürasyonu değişti. Önlem: hesap kapatma, MFA, konfigürasyon geri yükleme, segmentasyon. Sorumlu: BT, bakım, safety, uyum.

5. **14 gün — son rapor:** Hangi loglar/kayıtlar korunmuş olmalı?

Korunmalı: servis hesabının tam oturum ve kimlik logları, jump server ve VPN kayıtları, PLC/Safety PLC konfigürasyon yedekleri (öncesi/sonrası), ağ ve firewall logları. Write-once ortamda, erişimi kontrollü saklanmalı.

En sık hata: "Resetleyip devam edelim" — o düğme, kanıtı sonsuza dek siler. Önce emniyet, hemen sonra kanıt.

Bu föyün çıktısı **Incident Workflow** → Evidence Pack **EP 13 Incident Response** başlığına oturur.